Nätverksdesign – Trådlösa nätverk

LABORATION 3
Wireshark & Security

Laborant 1:
Laborant 2:
Laborant 3:

Supervisor: Sigurd Israelsson
Supervisor: Viktor Ljunggren

1. GOAL

Your goal is to capture Wi-Fi traffic as well as to test and evaluate common security controls. To do this, you must first set up a small wireless network.

1.2 PREREQUISITES

Necessary equipment:

- 15.4W PoE capable switch
- Cisco 2901 router
- Cisco 2504 WLC
- Cisco 2702.1 AP
- Alfa USB NIC
- Kali Linux 2024.3 (Virtualbox VM – provided by supervisor)
- Client device

Lab 2 should be completed before you start this lab.

You are assumed to have participated in earlier lectures in the course. Lecture 4 is especially important as it covers 802.11 MAC and wireless security.

1.3 REFERENCES

Chapter 16 and 17 in the course literature (CWNA) discuss wireless security risks and controls respectively.

1.4 EXAMINATION AND GRADING

Work in groups of 3 students. One lab session is scheduled for this assignment but more time may be required. Deadline for the assignment is **one week** from the lab session. This assignment is examined through a **lab report**. Use the separate lab report template on Canvas.

2. Instructions

Use the separate lab report template in canvas when answering questions from the instructions.

2.1 Preparation

To be able to capture and view all 802.11 frames that are transmitted through the air your NIC needs to be set to monitor mode. This is often not possible to do in Windows, and many wireless NIC chipsets do not support monitor mode.

We only have a few wireless NICs which support monitor mode, please only borrow one when you need too. To capture traffic, you also need to bypass Windows restrictions, which is why this lab use Kali Linux. Therefore, begin with installing a Kali Linux 2024.3 Virtualbox VM from https://www.kali.org/get-kali/#kali-virtual-machines

Note that the wireless NICs only support one MIMO spatial stream.

2.2 Preparing WLC

Use a Cisco AP 2702 and connect it to a Cisco WLC. Configure an open WLAN with a unique SSID which clearly states that this is a lab network that should not be joined (use lab 2 as reference).

To ensure that the wireless NIC is listening on the same frequency band as the client, disable the 5 GHz radio either during the initial configuration or through *Wireless -> 802.11a/n/ac*.

Cisco AP 2702 supports up to three MIMO spatial streams. Since the wireless NICs do not support multiple spatial streams it is necessary to ensure that the client does not communicate with MIMO. You can control the supported number of spatial streams on 2.4 GHz by disabling 802.11n data rates. All data rates but MCS index 0-7 should be disabled.

Lastly to successfully capture traffic, you must also know what channel the LAP is transmitting on. To do so, disable dynamic channel assignment (DCA) and assign the radio to a static channel.

Hint! Use a Wi-Fi analyser and a client to ensure that the preparations are correct.

Note! Some clients may automatically disconnect from networks without Internet-connectivity. Make sure that the Wi-Fi client stays connected to your wireless network by cancelling the disconnect prompt.

2.3 Preparing Kali

Ask a supervisor for a USB with a pre-patched Kali VM. Then copy the files from the USB to your computer. After that, add the VM in your virtualbox client.

Before powering up the VM, in VirtualBox under *Settings/USB* double-check that the WNIC is passthrough to the new VM.

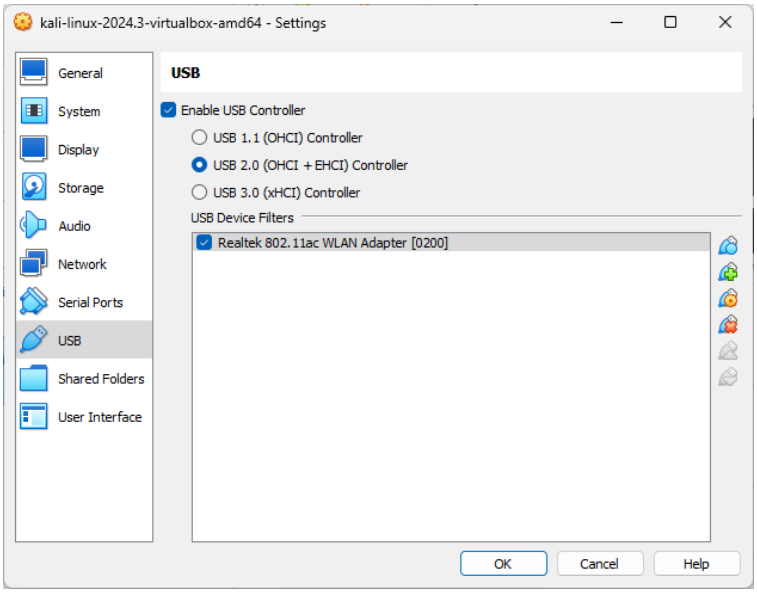

Figure 1. VirtualBox USB-passthrough

Power up the VM. Then make sure that the USB WNIC is detected by issuing the command `lsusb` (figure2)

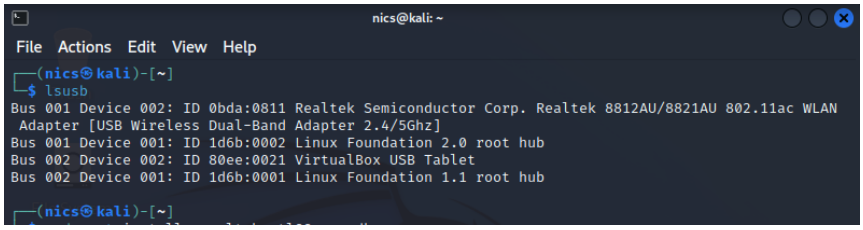

Figure 2. Verify lsusb

If the WNIC is not detected, press usb at the top of the virtualbox window and press on the WNIC-adapter in the drop-down menu. The WNIC should now show up with lsusb.

After you've verified that the WNIC is detected as a USB-device by the Kali VM, then you should be able to see an interface called `wlan0` with `Mode:Managed` when running the `iwconfig` command.

A managed interface means that it is configured for regular client operation. If you were to connect to an access point, this would be the mode you want. If you wanted to capture traffic in managed mode, you would need to connect to the WLAN first. Furthermore, it would only capture data frames within your WLAN that is addressed to you in some way, either explicitly or by broadcast.

Another option you might have heard of is *promiscuous mode*. Putting a NIC in promiscuous mode turns of the MAC-filter that is used in managed mode but still

requires you to be connected to a WLAN to capture traffic. For the purpose of this lab we are portraying an eavesdropper that do not have authentication credentials for the network. To be able to capture all frames, whether we are associated or not, and no matter who the frames are addressed to, we need to set our NIC to *monitor mode.*

To change `wlan0` to *monitor mode*, run the command **`airmon-ng start wlan0`**. Once run, we are notified of two processes that might interfere with our capture. Kill the potentially interfering processes by typing **`kill`** followed by the PID (figure 4).

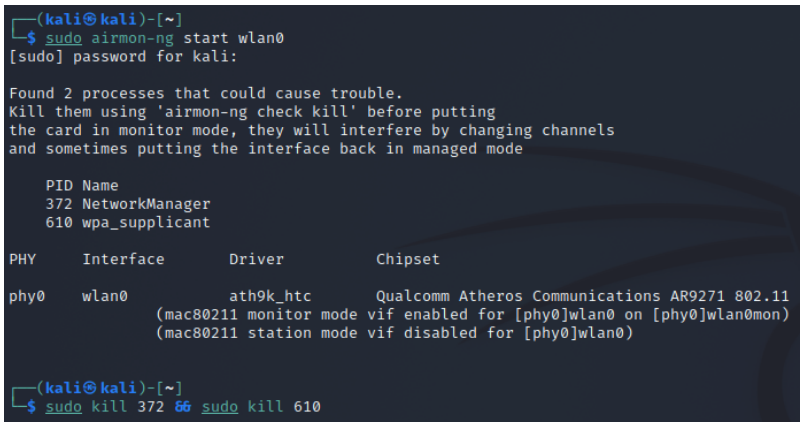

Figure 4. Use airmon-ng to enable monitor mode

Now that there are no interfering processes, restart `wlan0` and specify the channel you want to listen to. In this example the channel is set to 11.

```
sudo airmon-ng stop wlan0
sudo airmon-ng start wlan0 11
```

Use **`iwconfig`** to verify that your interface is up and set to an appropriate channel. If everything looks correct you are now ready to start capturing traffic with Wireshark. However, you must first read all instructions from the next chapter (2.4).

2.4 WIRESHARK

IMPORTANT!!!

READ THIS ENTIRE CHAPTER BEFORE STARTING YOUR CAPTURE

To not violate any laws, you <u>MUST</u> add a capture filter so that you do not capture any traffic besides your own. Before you begin the packet capture, filter on the MAC-address of your wireless client. This will only allow capture of traffic to and from your own client device.

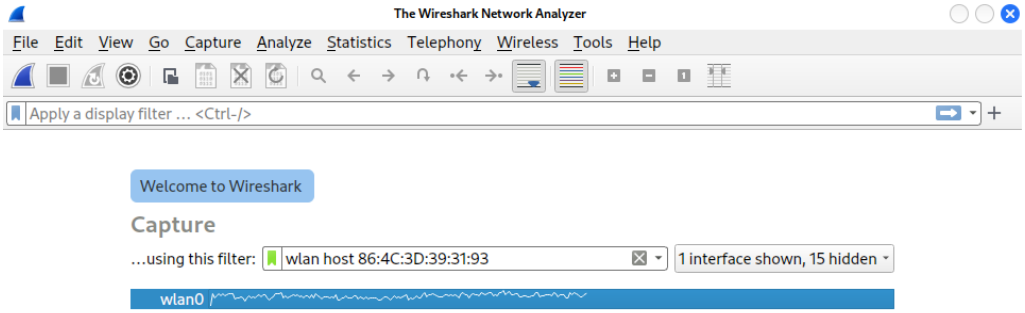

Figure 5. Capture filter for wlan0

Note! The client MAC-address is often unique and randomly chosen per SSID, though this can usually be disabled on the client device.

Then under *<u>C</u>apture/Options* at the top of the Wireshark window untick *promiscuous mode* from the `wlan0` interface.

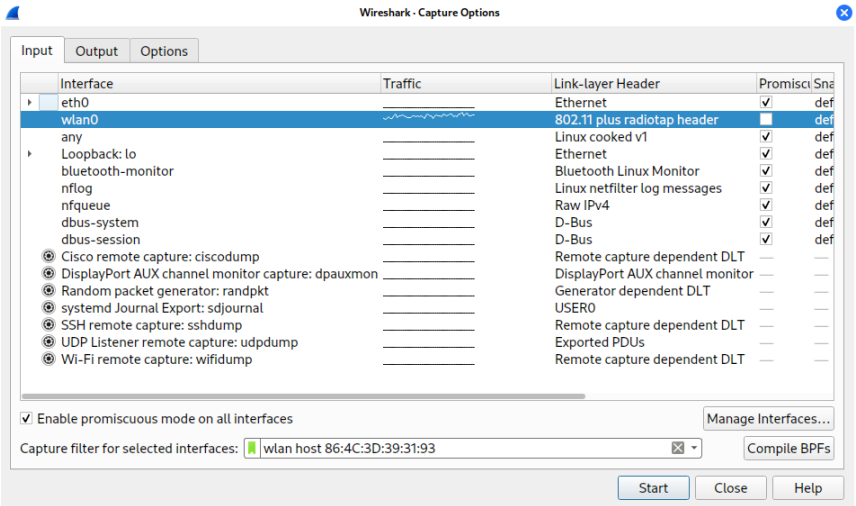

Figure 6. Interface promiscuous mode

Once you have set the capture options you can press *start* to begin the packet capture.

Feel free to ask your supervisor for assistance if you aren't sure that your capture options are correct.

ALWAYS STOP THE CAPTURE AS SOON AS YOU HAVE WHAT YOU NEED

IMPORTANT!!!

2.5 Management Frames

There are three different kinds of Wi-Fi frames, which all have corresponding Wireshark display filters.

Management Frames	`wlan.fc.type == 0`
Control Frames	`wlan.fc.type == 1`
Data Frames	`wlan.fc.type == 2`

There are many management frames which can quickly fill up your capture input, use the tables to filter out uninteresting frames.

Association Request	`wlan.fc.type_subtype == 0x00`
Association Response	`wlan.fc.type_subtype == 0x01`
Probe Request	`wlan.fc.type_subtype == 0x04`
Probe Response	`wlan.fc.type_subtype == 0x05`
Beacon	`wlan.fc.type_subtype == 0x08`
Disassociate	`wlan.fc.type_subtype == 0x0A`
Authentication	`wlan.fc.type_subtype == 0x0B`
Deauthentication	`wlan.fc.type_subtype == 0x0C`
Action	`wlan.fc.type_subtype == 0x0D`

Hint! You can combine multiple filters with "and" & "or". You can also negate a filter by prepending "not". For more complex filtering parentheses should be used.

1. **Management frames – Probe Request & Probe Response frames**

   Look through your packet capture, can you find any probe frames? Include a screenshot which clearly show both the *SSID* and the supported *data rates* of your network.

2. **Management frames – Authentication & Association frames**

   Start a new capture and connect to the network with a client and then disconnect from the network.

   Look through the new packet capture, which packets are involved when *connecting/disconnecting* to an open network? Include a screenshot which clearly shows the process.

   Note! It may take a while for clients to properly disconnect. If this is the case the disconnect portion can be skipped.

2.6 Data Frames

Data frames are somewhat easier to find, simply use the table below to answer the questions.

Data Frames	`wlan.fc.type == 2`
QoS Data	`wlan.fc.type_subtype == 0x28`

3. **Data frames – Open Access**

   Start a new packet capture and connect to your network. Use the client to connect to the router using telnet.

   Include a screenshot with the plaintext client requests where the password is clearly visible.

   Note! If you cannot use Telnet on your client device, show a cleartext HTTP request to the client gateway instead.

4. **802.11 frames – MAC-addresses**

   Normal 802.3 frames contain two MAC-addresses, a source and destination address. Wireless 802.11 frames contain a total of four MAC-addresses.

   Explore the packet capture and select a unicast QoS data frame. Include a screenshot of its MAC-addresses and an explanation of which MAC-addresses belong to which device.

2.7 WPA2

Update your WLAN and change the encryption/authentication method to WPA2-PSK. Then while performing a packet capture, connect to your network and use Telnet to authenticate to the router.

Note! If you cannot use Telnet on your client device, perform a cleartext HTTP request to the client gateway instead.

5. WPA2 – 4-way Handshake

WPA2 uses a more complex authentication exchange called a 4-way handshake. The 4-way handshake occurs between the client and the AP during association (using the EAPOL-protocol).

Include screenshots which clearly show the 4-way handshake as well as the encrypted traffic (should be marked as QoS-Data).

If you know the PSK and have the 4-way handshake you can decrypt the wireless traffic. As a proof of concept input the PSK in Wireshark.

Go to *Edit/Preferences/Protocols/IEEE802.11*, check the box *Enable decryption* and input your decryption key. Choose the *Key type* "*WPA-PWD*" and enter the key in the format "*PSK:SSID*" (e.g. My PSK:My SSID).

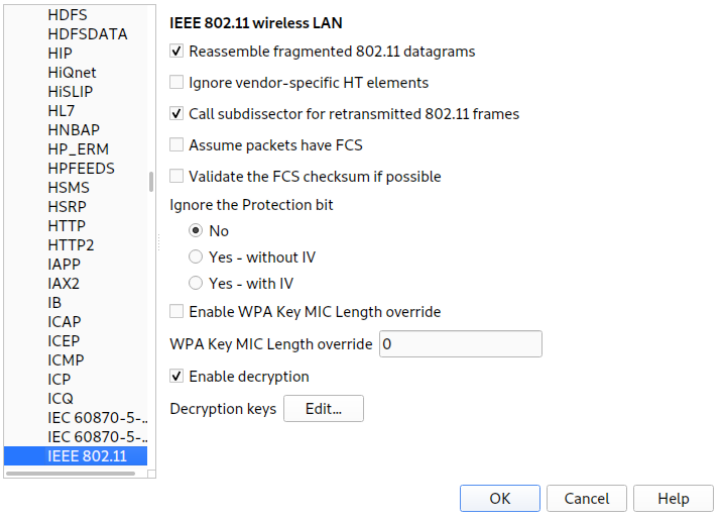

Figure 7. Options for decrypting WPA

6. WPA2 – Decryption

Include a screenshot of successfully decrypted WPA2 traffic with the plaintext client requests, where the password is clearly visible.

Note! If you cannot use Telnet on your client device, show a cleartext HTTP request to the client gateway instead.

2.8 Management Frame Security

Changing an Open Access Wi-Fi to WPA2-protected Wi-Fi can greatly improve security by protecting access to the network and hindering wireless snooping. Though there are more security vulnerabilities in Wi-Fi that can still be exploited with WPA2-encryption/authentication configured.

One of the more popular attack vectors are management frames, which can be exploited to perform denial of service attacks (DoS). Since these frames are not encrypted or authenticated any wireless client can send spoofed management frames to cause network disruption.

7. **Denial of Service – Management frames**

   Briefly explain why management frames are hard to protect – *why can't they just be encrypted like the QoS data frames?* One to two sentences can be enough.

IMPORTANT!!!
To not violate any laws, only perform the following exploits on networks and clients which you have permission to disrupt

Find the MAC-address of your LAP BSSID (e.g. through a Wi-Fi Analyzer). Connect to your network with a wireless client. Then from your Kali machine run the following command substituting the MAC-address in "`-d`" with your LAP radio MAC-address (i.e. BSSID). Also specify the correct channel of the BSS in "`-c`".

```
sudo airodump-ng -d 04:62:73:48:7A:F0 -c 11 wlan0
```

Start a Telnet session on the client, then from the Kali machine run the following command to forcefully remove the client from your wireless network. Substitute the MAC-address in "**-a**" with the LAP BSSID, and the MAC-address in "**-c**" with the MAC-address of your client.

```
sudo aireplay-ng -0 0 -a 04:62:73:48:7A:F0 -c E2:37:E4:67:33:76 wlan0
```

IMPORTANT!!!
If you are unsure about any settings or instructions ask a supervisor for assistance

8. **Denial of Service – Management frames**

   What happens to the client connection?

   Include screenshots of the aireplay-ng terminal and Wireshark showing deauthentication frames. Then stop the attack with Ctrl-C.

To protect against the abuse of management frames the feature Protected Management Frames (PMF) can be used. PMF hinders spoofing of certain management frames by replacing them with so called robust management frames.

Activate PMF for your network, then attempt the attack once more. Are you successful?